



ISO 14971:2019 +A11:2021

Application of Risk Management to Medical Devices

Part A: Standard Overview & Requirements

Training Session | Nordberg Medical | Orderly People – Jonas Jägerback and Erica Sundgren

Agenda

01 Introduction & Scope

What ISO 14971 is and what it covers

02 Key Terms & Definitions

Building a shared vocabulary

03 General Requirements

Process and planning, top management, competence, RMF

04 Risk Analysis

Hazard identification and risk estimation

05 Risk Evaluation & Control

Acceptability, controls, verification

06 Overall Residual Risk & Review

Big-picture assessment

07 Post-production & PMS

Feedback loops, trend analysis

How many are new to ISO 14971?

Give a “thumbs up”  reaction over MS Teams

Why Risk Management for Medical Devices?



Patient Safety

Risk management ensures potential harms are identified and controlled before they reach patients.



Regulatory Requirement

Required by
EU MDR, US FDA and ISO 13485

It is not optional – it is a
legal requirement for market access



Lifecycle Approach

Post-market data, complaints, and trend analysis must feed back into risk management continuously.

What is ISO 14971?

The internationally recognized standard for applying risk management to medical devices.

Current edition, as of March 2026: **ISO 14971:2019 + A11:2021**

Companion guidance: **ISO/TR 24971:2020**

Applies to all medical devices.

Key Principle

Risk management shall be an integral part of the overall lifecycle of a medical device

- from initial conception,
- through design,
- production, and
- throughout its lifetime.

Scope ISO 14971

Medical devices — Application of risk management to medical devices

1 Scope

This document specifies terminology, principles and a *process* for *risk management* of *medical devices*, including software as a *medical device* and *in vitro diagnostic medical devices*. The *process* described in this document intends to assist *manufacturers* of *medical devices* to identify the hazards *associated with the medical device*, to estimate and evaluate the associated *risks*, to control these *risks*, and to monitor the effectiveness of the controls.

The requirements of this document are applicable to all phases of the *life cycle* of a *medical device*. The *process* described in this document applies to *risks* associated with a *medical device*, such as *risks* related to biocompatibility, data and systems security, electricity, moving parts, radiation, and usability.

Where Does ISO 14971 Fit?

EU MDR 2017/745

Annex I GSPRs, Art. 10

ISO 13485:2016

QMS / §7 Product realization

IEC 62366-1

Usability Engineering



ISO 14971:2019

Risk Management Process

US FDA QMSR

ISO14971 Recognized consensus standard

ISO/TR 24971:2020

Guidance & examples

ISO 10993 series

Biological evaluation

... and more!

EU MDR & Risk Management

MDR Article 10 + GSPR

Article 10(2) requires manufacturers to establish, document, implement, and maintain a risk management system.

Annex I GSPRs 1-9 define the core risk management requirements for design and manufacture.

Compliance with ISO 14971 is the primary pathway to demonstrate conformity with these obligations.

Examples of key GSPRs

- **GSPR 1** “any risks which may be associated with [device] use constitute acceptable risks when weighed against the benefits”
- **GSPR 2** mandates “reduction of risks as far as possible without adversely affecting the benefit-risk ratio”
- **GSPR 3** mandates a risk management system (implicitly aligning with ISO14971 structure)
- **GSPR 4** requires inherent safe design first, then protective measures, then information for safety
- **PMS/Vigilance** obligations under MDR Article 83-89 directly feed into ISO 14971 §10

US FDA QMSR & Risk Management

QMSR - What Changed?

In February 2026, the FDA's Quality Management System Regulation (QMSR) replaced the old 21 CFR 820 Quality System Regulation (QSR). The QMSR incorporates ISO 13485:2016 by reference, aligning the US more closely with international standards.

Aspect	US FDA QMSR
Risk management approach	Aligned with ISO 13485:2016 §7.1 → ISO 14971 as the expected method
Design controls	Risk-based approach integrated throughout design and development
Post-market	Feedback loop requirement (per ISO 14971 §10)
International alignment	Harmonized with ISO 13485, reducing gap for multi-market manufacturers

CLAUSE 3

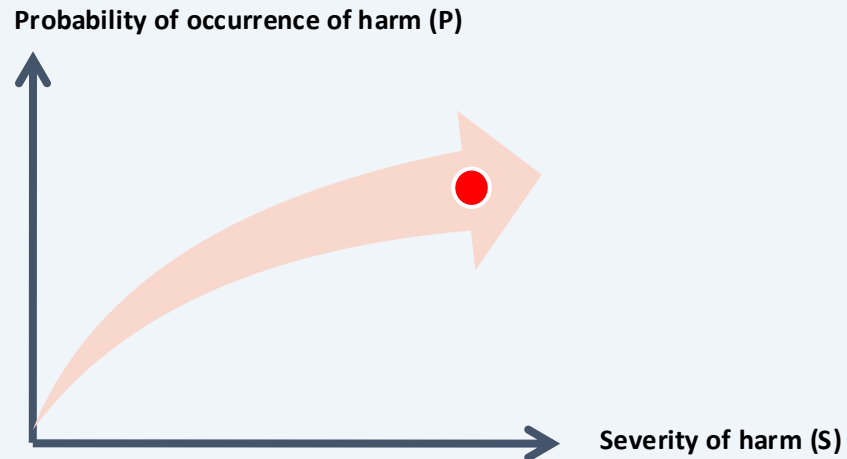
Key Terms & Definitions

Building a shared vocabulary

Key Terms & Definitions

Risk

Combination of the probability of occurrence of harm and the severity of that harm.



Key Terms & Definitions

Limits the scope of ISO14971 Risk management



Harm

Injury or damage to the health of people, or damage to property or the environment.

Hazard

Potential source of harm.

Hazardous situation

Circumstance in which people, property or the environment are exposed to one or more hazards.

Residual risk

Risk remaining after risk control measures have been implemented.

Key Terms & Definitions

Risk analysis

Systematic use of available information to identify hazards and to estimate the risk.

Risk evaluation

Process of comparing the estimated risk against given risk criteria to determine the acceptability of the risk.

Risk control

Process in which decisions are made and measures are implemented by which risks are reduced to, or maintained within, specified levels.

Reasonably foreseeable misuse

Use of a product or system in a way **not intended** by the manufacturer, but which can result from readily predictable human behavior

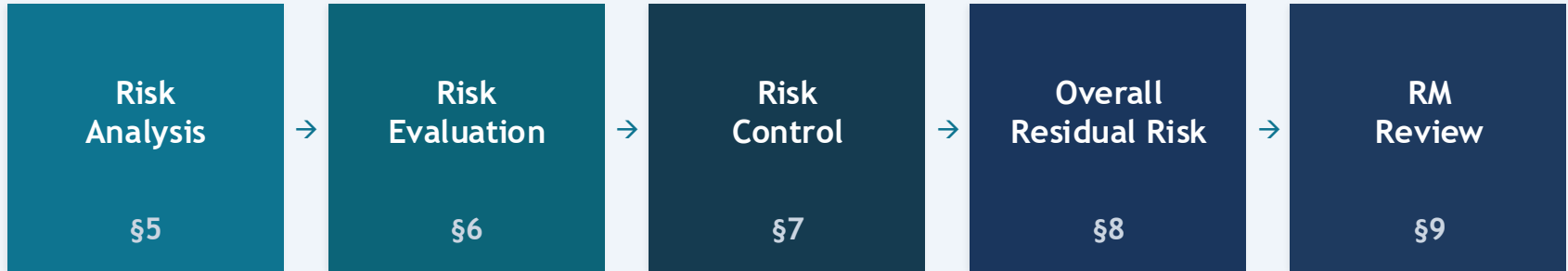
In PMS, “if you saw it once, it might happen again” → Reasonably foreseeable

CLAUSE 4

General Requirements

Process and planning, top management, competence, RMF

The Risk Management Process - Overview



Risk Management Plan (§4.4)

Defines scope, criteria, verification activities, and responsibilities. Established **before** you begin.



Production & Post-production (§10)

Continuous collection of post-market data feeding back into risk management.

↻ Continuous feedback loop throughout product lifecycle

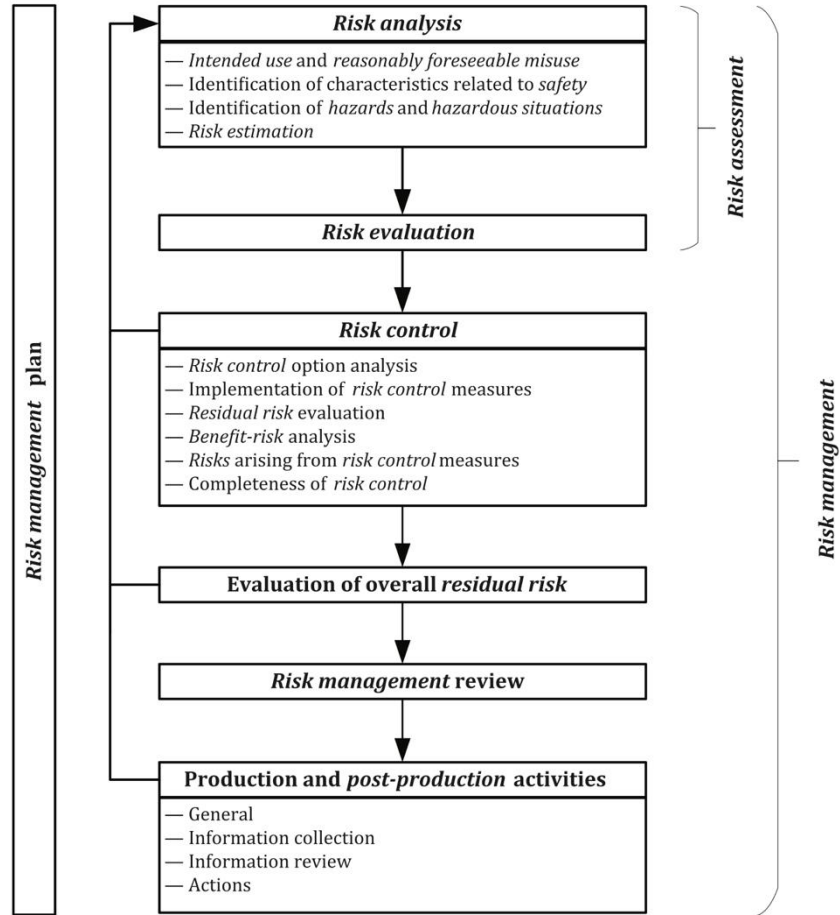


Figure 1 — A schematic representation of the *risk management process*

The Risk Management File (\$4.5)

The RMF is the central repository for all risk management records. It provides traceability and evidence of compliance.



Risk Management Plan

Defines scope, criteria, and approach



Risk Analysis Records

Hazard identification, hazardous situations, risk estimation



Risk Evaluation Records

Acceptability decisions with rationale



Risk Control Records

Measures, verification of implementation & effectiveness



Overall Residual Risk

Final overall benefit-risk evaluation



Risk Management Review

Completeness check before commercial release

Management responsibilities & Competence (§4.2-4.3)



Management responsibilities (4.2)

Shall ensure:

- Adequate resources allocated for risk management
- Qualified personnel assigned
- Documentation of a policy for establishing criteria for risk acceptability ("risk policy")
- Regular review of the suitability of the risk management process



Competence of personnel (4.3)

Personnel performing risk management shall be competent based on:

- Education
- Training
- Skills
- Experience

Records of competence and training shall be maintained and traceable.

Risk policy , Policy for establishing criteria for risk acceptability



Management responsibilities §4.2

*“Top management shall define and document a **policy for establishing criteria for risk acceptability**. The policy shall provide a framework that ensures that criteria are*

- based upon applicable national or regional **regulations** and*
- relevant **international standards**, and*
- take into account available information such as the generally acknowledged **state of the art** and*
- known **stakeholder concerns**. “*

Risk policy , Policy for establishing criteria for risk acceptability



ISO/TR 24971 Annex C guidance

- The risk policy concerns **both** acceptability of individual risks, and overall residual risk
- Must be documented, e.g., as part of the QMS (not necessarily as part of RMF)
- The risk policy typically address
 - a) Purpose
 - b) Scope
 - c) Factors and considerations for determining acceptable risk
 - d) Approaches to risk control
 - e) Requirements for approval and review

The policy should be tailored to fit the specific needs of the manufacturer's organization.

Risk policy

, Policy for establishing criteria for risk acceptability



Risk policy example

Purpose

- The ***purpose*** of the risk policy is to provide guidance for establishing the criteria for risk acceptability. These criteria are used in the evaluation of residual risks associated with the medical devices manufactured by Nordberg Medical. The criteria will ensure that the medical devices have a high level of safety consistent with stakeholder expectations.

Scope

- The policy ***applies*** to all persons involved in establishing, reviewing, updating, and approving the criteria for risk acceptability in risk management plans for medical devices designed and manufactured by Nordberg Medical for commercial distribution.

Factors and considerations

- The following ***factors*** should be considered when establishing the criteria for risk acceptability:
- Applicable regulatory requirements in the regions where the medical device is to be marketed,
 - Relevant internal standards for the particular medical device being developed or manufactured,
 - The generally acknowledged state of the art, which can be determined from a review of international standards, best practices in technology, results of accepted scientific research, publications from authorities, and other information for similar medical devices.
 - Validated concerns from stakeholders, e.g., information from users, clinicians, patients or regulatory bodies.

Approach to risk control

- Risks shall be reduced ***as far as possible without adversely affecting the benefit-risk ratio***. Consideration is given to whether technically practicable risk control measures would reduce the risk without impacting the benefit of the device.

Req for approval and review

- The policy for establishing the criteria for risk acceptability is ***approved*** by the Head of Quality, and is ***reviewed*** annually by Top Management as part of reviewing the suitability of the risk management process (addressed in Management Review).

The Risk Management Plan (\$4.4)

The Risk Management Plan defines the roadmap for all risk management activities.

Plan Contents

The Risk Management Plan shall include **at least** the following:

- Scope of the planned risk management activities
- Assignment of responsibilities and authorities
- Requirements for review of risk management activities
- Criteria for risk acceptability (appropriate for the *particular device*) → **Essential for ultimate effectiveness of RM process**
- Method to evaluate Overall residual risk + Criteria for its acceptability (based on the **risk policy**)
- Verification activities for Risk control measures
- Activities related to collection and review of production and post-production information

CLAUSE 5

Risk Analysis

Hazard identification and Risk estimation

Intended Use & Reasonably Foreseeable Misuse (§5.2)

✓ Intended Use

The manufacturer shall document:

- Medical indication / intended purpose
- Patient population (age, health, anatomy)
- Body part / tissue interaction
- User profile (clinician, self-use)
- Use environment
- Operating principle

⚠ Reasonably Foreseeable Misuse

The manufacturer must also consider, and document:

- Incorrect preparation or handling
- Use by untrained personnel
- Use errors that are readily predictable based on human behavior
- Not limited to the IFU
- Off-label use that is clinically common (ISO/TR 24971)



Key Insight: "Abnormal use" vs. "Reasonably foreseeable misuse"

Abnormal use (IEC 62366: conscious, deliberate misuse) is not defined in **ISO14971** – if a misuse is **reasonably foreseeable**, even if it contradicts the IFU, it is in scope of **Risk Management**.

E.g., for injectable devices, if clinical literature shows off-label injection areas is common, this is in scope of your risk analysis.

Identification of Characteristics related to safety (§5.3)

The manufacturer shall identify and document **device characteristics** that could affect safety.

Supportive approaches

- a) **Annex A of ISO/TR 24971** → Questions to guide in identifying safety characteristics + Factors to consider for each question
- b) **Similar devices** → Review available information, literature and adverse events reports
- c) **Regulations and standards** → Guidance on device-specific safety characteristics
- d) **Derived from 'Essential performance'**
 - Characteristics related to loss or degradation of clinical performance that can result in **unacceptable risk**
 - Identify the device functions or performance that are necessary to achieve its intended use (or that could affect safety)
 - Consider whether any hazardous situations could occur, if any of these functions did not perform properly.

→ **Understanding device safety characteristics supports hazard identification**

NOTE 'Essential performance' (IEC 60601-1), means performance of a clinical function [...] where loss or degradation beyond the limits specified by the manufacturer results in an unacceptable risk.

Identification of Hazards & hazardous situations (§5.4)

The manufacturer shall identify and document known and foreseeable hazards associated with the medical device based on the

- a) intended use,
 - b) reasonably foreseeable misuse, and
 - c) characteristics related to safety
- } in both normal and fault conditions.

Sources of information for Hazard identification

- Clinical data and literature reviews
- Similar device history (predicate, equivalent)
- Standards and guidance documents
- Usability studies and formative evaluations
- Manufacturing process records and NCs
- Expert opinion and brainstorming sessions
- Post-market surveillance data (complaints, incidents)

ISO14971 Annex C - Hazard examples

- Energy (electrical, mechanical, radiation)
- Biological
- Chemical
- Immunological
- Environmental
- Data
- Functional

Energy hazards	Biological and chemical hazards	Performance-related hazards
Acoustic energy	Biological agents	Data
— infrasound	Bacteria	— access
— sound pressure	Fungi	— availability
— ultrasonic	Parasites	— confidentiality
Electric energy	Prions	— transfer
Electric fields	Toxins	— integrity
Leakage current	Viruses	Delivery
— earth leakage	Chemical agents	— quantity
— enclosure leakage	Carcinogenic, mutagenic, reproductive	— rate
Magnetic fields	Caustic, corrosive	Diagnostic information
Static discharge	— acidic	— examination result
Voltage	— alkaline	— image artefacts
Mechanical energy	— oxidants	— image orientation
Kinetic energy	Flammable, combustible, explosive	— image resolution
— falling objects	Fumes, vapors	— patient identity / information
— high pressure fluid injection	Osmotic	Functionality
— moving parts	Particles (including micro- and nano-particles)	— alarm
— vibrating parts	Pyrogenic	— critical performance
Potential (stored) energy	Solvents	— measurement
— bending	Toxic	
— compression	— asbestos	
— cutting, shearing	— heavy metals	
— gravitational pull	— inorganic toxicants	
— suspended mass	— organic toxicants	
— tension	— silica	
— torsion	Immunological agents	
Radiation energy	Allergenic	
Ionizing radiation	— antiseptic substances	
— accelerated particles (alpha particles, electrons, protons, neutrons)	— latex	
— gamma	Immunosuppressive	
— x-ray	Irritants	
Non-ionizing radiation	— cleaning residues	
— infrared	Sensitizing	
— laser		
— microwave		
— ultraviolet		
Thermal energy		
Cryogenic effects		
Hyperthermic effects		

Hazardous Situations & Risk Estimation (§5.4-5.5)



Risk Estimation (§5.5)

For each identified hazardous situation, the manufacturer shall estimate the risk using:

Probability of occurrence of harm (P)

How likely is the harm to occur?

→ Supported by e.g., similar device data, tests and simulations, production and PMS data, standards, expert judgement, etc.

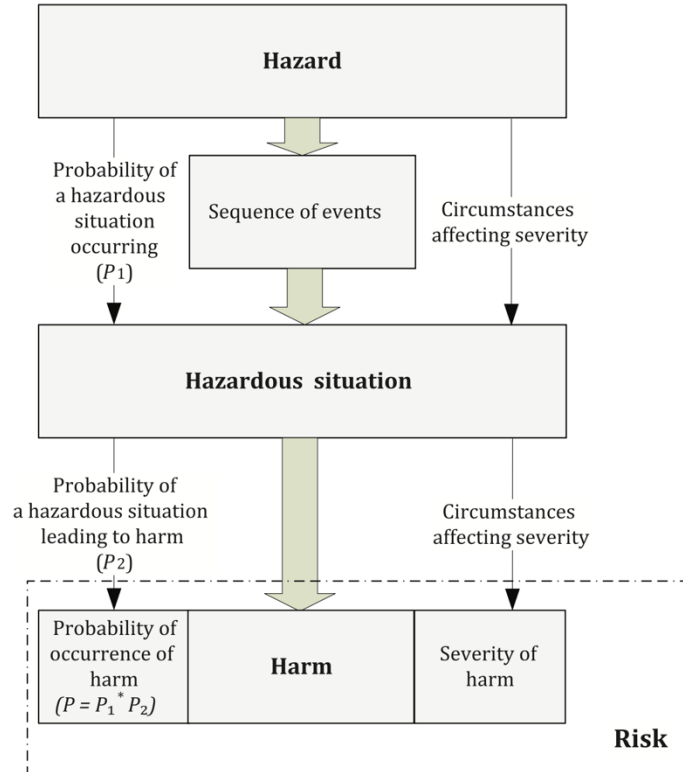
×

Severity of Harm (S)

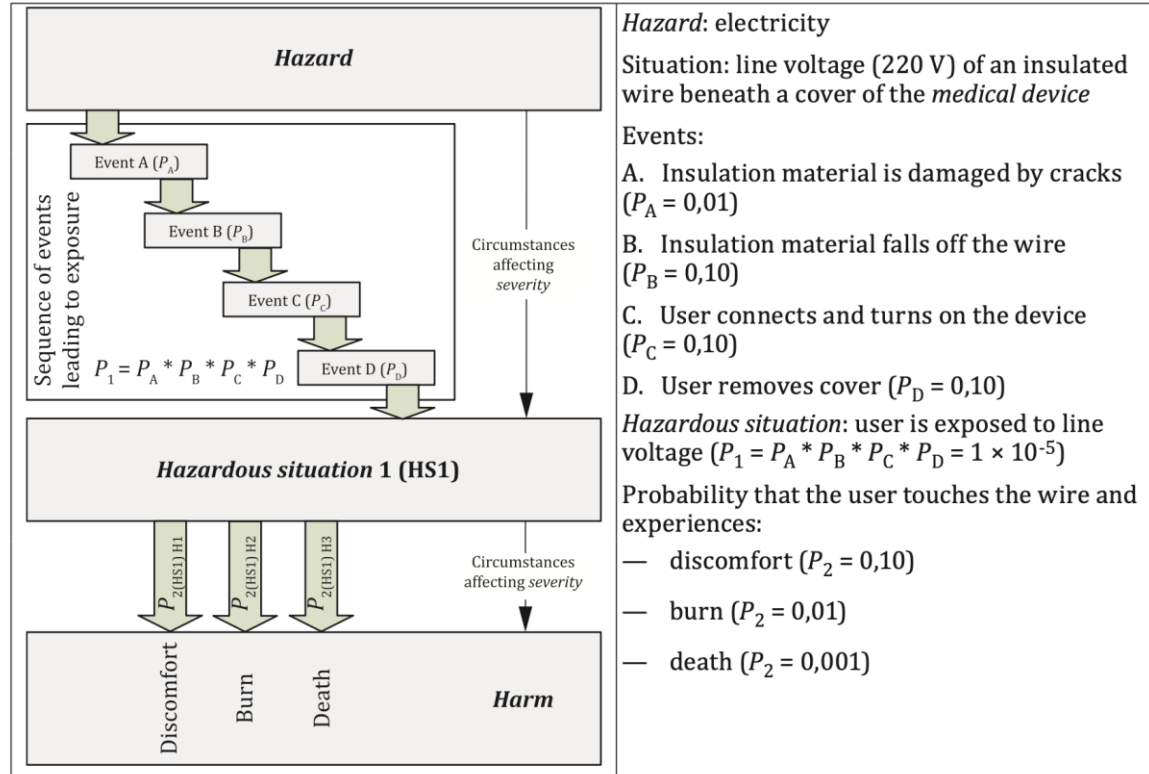
How serious is the potential harm?

→ Supported by clinical expert judgement

Probability = $P_1 \times P_2$



ISO/TR 24971 Example



Three risks with various Harms, P and S → Distinguish by 3 Risk IDs

Hazard to Harm (ISO14971 example)

<i>Hazard</i>	<i>Foreseeable sequence of events</i>	<i>Hazardous situation</i>	<i>Harm</i>
Electromagnetic energy (high voltage)	(1) Electrode cable unintentionally plugged into power line receptacle	Line voltage appears on electrodes	Serious burns Heart fibrillation
Chemical (volatile solvent, embolus)	(1) Incomplete removal of volatile solvent used in manufacturing (2) Solvent residue converts to gas at body temperature	Development of gas embolism (bubbles in the blood stream) during dialysis	Infarct Brain damage
Biological (microbial contamination)	(1) Inadequate instructions provided for decontaminating re-used anaesthesia tubing (2) Contaminated tubing used during anaesthesia	Bacteria released into airway of patient during anaesthesia	Bacterial infection
Functionality (no delivery)	(1) Electrostatically charged patient touches infusion pump (2) Electrostatic discharge (ESD) causes pump and pump alarms to fail	Failure to deliver insulin to patient with elevated blood glucose level, no warning given	Minor organ damage Decreased consciousness
Functionality (no output)	(1) Implantable defibrillator battery reaches the end of its useful life (2) Inappropriately long interval between clinical follow-up visits	Defibrillator cannot deliver shock when an arrhythmia occurs	Death
Measurement (incorrect information)	(1) Measurement error (2) No detection by user	Incorrect information reported to clinician, leading to misdiagnosis and/or lack of proper therapy	Progression of disease Serious injury

Probability levels (ISO/TR 24971 examples)

Table 5 — Example of five semi-quantitative probability levels

Common terms	Examples of probability range
Frequent	$\geq 10^{-3}$
Probable	$< 10^{-3}$ and $\geq 10^{-4}$
Occasional	$< 10^{-4}$ and $\geq 10^{-5}$
Remote	$< 10^{-5}$ and $\geq 10^{-6}$
Improbable	$< 10^{-6}$

*) Defined as the probability of occurrence of harm associated with one use of the device.

Table 3 — Example of three qualitative probability levels

Common terms	Possible description
High	Likely to happen, often, frequently, always Likely to happen several times during the lifetime of the <i>medical device</i>
Medium	Can happen, but not frequently Likely to occur a few times during the lifetime of the <i>medical device</i>
Low	Unlikely to happen, rare, remote Not likely to occur during the lifetime of the <i>medical device</i>



... Probability of what?

Don't forget to state how probability is defined, e.g., probability of occurrence of harm **per use**, **per device**, or other suitable reference.

ISO14971 supports **quantitative** and **qualitative** probability levels. When sufficient data are available to estimate P with adequate confidence, a quantitative method should be used. Otherwise, a qualitative method based on expert judgement may be preferred (e.g., for an entirely new MD, lacking suitable quantitative data).

Severity levels (ISO/TR 24971 examples)

Table 4 — Example of five qualitative *severity* levels

Common terms	Possible description	Examples of harms
Catastrophic / Fatal	Results in death	Stroke, ...
Critical	Results in permanent impairment or irreversible injury	Loss of vision, ...
Serious / Major	Results in injury or impairment requiring medical or surgical intervention	Bone fracture, ...
Minor	Results in temporary injury or impairment not requiring medical or surgical intervention	Brusing, ...
Negligible	Results in inconvenience or temporary discomfort	Itching, ...

Aligning terms and descriptions with terminology used in regulations can be useful in describing the levels of severity. E.g., aligning Severity-level “**Serious**” with the threshold of EU MDR “**Serious incident**”.

Integrate identified harms in Severity table

To facilitate consistency in Severity-ranking of identified harms, the Severity-table can be populated with all harms identified for the specific device, at appropriate Severity-level.

When defining harms, utilizing established IMDRF / MedDRA AE terminology can be beneficial, facilitating future trend reporting.

How to estimate Probability?



Supporting your estimates

There is no requirement mandating **how** to estimate Probability, this is up to the manufacturer. When possible, leverage **objective evidence** to support your estimates, utilizing e.g.,

1. **Clinical literature and scientific articles** (e.g., your CER might reference a review of multiple clinical trials of PLLA fillers, reporting nodule formation incidence of 5% of treated patients, directly informing probability estimate)
2. **Industry standards ***
3. **Statistical references** (e.g., national health authority data, epidemiological database information, etc.)
4. **PMS data, or similar device information** (e.g., adverse events reported to FDA MAUDE)
5. **Tests and investigations** (e.g., usability studies, mechanical stress testing, simulations, process validation, etc.)
6. **Expert judgement** ("qualified guessing", can be supported by e.g., the Delphi method)
 - Often required for *brand new products*, without similar devices on the market
 - Critical risks with severe consequences of vague Probability-estimates, should be supported more robustly than only by "expert judgement". E.g., investing time and money in testing

*) E.g., IEC 60601-1 specifies maximum leakage current limits; if your device is designed with appropriate margin to the limit, the standard's underlying failure assumptions can support a "remote" or "improbable" probability rating for electrical shock scenarios

Expert judgement - When experts disagree?



Delphi method (1/3)

What it is - A structured way of turning individual expert opinions into a reliable group consensus, without the problems that come with open group discussions (where dominant personalities, groupthink, or seniority bias tend to skew the outcome).

Why use it - In risk management you sometimes face hazardous situations where no published data, test results, or field statistics exist to estimate probability. Rather than relying on one person's gut feeling, the Delphi method gives you a defensible, documented rationale by systematically harvesting and refining independent expert judgment.

Expert judgement - When experts disagree?



Delphi method (2/3)

How it works - The process is iterative and anonymous:

1. Define the specific question clearly (e.g., "What is the probability of X occurring during intended use?").
2. Select a panel of relevant experts (5-10 persons), each with relevant perspectives based on the question raised (clinical, design, manufacturing, etc.).
3. Each expert independently provides their estimate and a brief rationale, without knowing what others have answered.
4. A facilitator collects and summarizes the responses, sharing the anonymized distribution (e.g., range, median) and the key arguments back to the panel.
5. Each expert reviews the group summary and revises their estimate if they wish, again independently.
6. Repeat for 2-3 rounds until the estimates converge sufficiently.
7. The final consensus (often the median or interquartile range) becomes your documented probability estimate.

Expert judgement - When experts disagree?



Delphi method (3/3) - Illustrative example

Problem:

You are trying to estimate the probability that a clinician injects your PLLA filler into a non-indicated facial area, but there is insufficient published incidence data to adequately support a reliable estimation.

Solution:

1. You assemble a panel of five experts: three experienced aesthetic injectors, and two clinical trainers. In round one, estimates range widely from "uncommon" to "occasional." The facilitator shares this spread along with each expert's anonymized reasoning.
2. In round two, informed by each other's reasoning, the panel converges toward "uncommon" with a documented rationale tied to anatomical variability and injection technique.
3. That consensus, together with the recorded reasoning from each round, goes into your risk management file as the justification for your probability estimation.

CLAUSE 6

Risk Evaluation

Determining risk acceptability

Risk Evaluation (\$6)

For each identified hazardous situation, the estimated risk shall be compared to the **criteria for risk acceptability**.

Criteria for risk acceptability (example)

p \ s	1: Negligible	2: Minor	3: Serious	4: Critical	5: Catastrophic
5: Frequent					
4: Probable					
3: Occasional					
2: Remote					
1: Improbable					

 Acceptable  "Tolerable" (optional)  Unacceptable

Key Points

- Acceptability criteria are device-specific
- Defined in the Risk Management Plan
- Based on the manufacturer's risk policy
- ISO 14971 does not prescribe specific acceptance levels (up to manufacturer)

Question to the group

Let's imagine you were a stringent auditor at a Notified Body

You're reviewing the Risk Management File of a non-medical purpose dermal filler (single-use), would you remark on any of the below?

Probability (per device use)		
Level	Descriptor	Definition
P1	Improbable	< 1 in 100 000
P2	Remote	1 in 100 000 to 1 in 10 000
P3	Occasional	1 in 10 000 to 1 in 1 000
P4	Probable	1 in 1 000 to 1 in 100
P5	Frequent	> 1 in 100 device uses
Severity		
Level	Descriptor	Definition
S1	Negligible	Inconvenience or temporary discomfort
S2	Minor	Temporary injury or impairment, not requiring medical intervention
S3	Serious	Injury requiring professional medical intervention
S4	Critical	Permanent impairment or life-threatening injury
S5	Catastrophic	Death

Criteria for risk acceptability / "Risk acceptability matrix"							
Probability			Severity				
			1	2	3	4	5
	Improbable	1	ACC	ACC	ACC	ACC	ACC
	Remote	2	ACC	ACC	ACC	ACC	NOT-ACC
	Occasional	3	ACC	ACC	ACC	NOT-ACC	NOT-ACC
	Probable	4	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC
	Frequent	5	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC

Question to the group

For non-medical purposes devices, the EU Common Specifications (Regulation 2022/2346), raises the bar on risk management, as the benefit-side of the equation is weaker (no life-saving or therapeutic benefit).

Regulation 2022/2346, Annex I §3.3:

- 3.3. In defining the criteria for risk acceptability in accordance with the principles established by the policy referred to in Section 2.2, manufacturers shall consider that all risks, including those related to surgical intervention, are to be eliminated or reduced as far as possible. If the undesirable side-effects are of transient nature and do not require medical or surgical intervention to prevent life-threatening illness or permanent impairment of a body function or permanent damage to a body structure, residual risks may be considered as being acceptable. If one or more of the conditions laid down in this Section is not met, the manufacturer shall provide a justification explaining the reasons for the acceptability of the risks.

Question to the group

Criteria for risk acceptability / "Risk acceptability matrix"							
			Severity				
			1	2	3	4	5
Probability	Improbable	1	ACC	ACC	ACC	ACC	ACC
	Remote	2	ACC	ACC	ACC	ACC	NOT-ACC
	Occasional	3	ACC	ACC	ACC	NOT-ACC	NOT-ACC
	Probable	4	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC
	Frequent	5	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC



Criteria for risk acceptability / "Risk acceptability matrix"							
			Severity				
			1	2	3	4	5
Probability	Improbable	1	ACC	ACC	ACC	ACC	NOT-ACC
	Remote	2	ACC	ACC	ACC	NOT-ACC	NOT-ACC
	Occasional	3	ACC	ACC	ACC	NOT-ACC	NOT-ACC
	Probable	4	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC
	Frequent	5	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC

What if Severity 5 is never acceptable? (death)

*"How can we then include any
Severity 5 risks in our risk analysis?"*

Anyone could die of a rapidly escalating infection
(worst case: septic shock)

Question to the group

An impossible situation?

CLAUSE 7

Risk Control

Selecting, implementing, and verifying risk control measures

Risk Control Option Analysis (§7.1)

The manufacturer shall identify risk control measures using the following **priority order**:

1

Inherently safe design and manufacture

Eliminate the hazard or reduce the risk by design choices. This is the most effective approach.

Example: Choosing proven biocompatible materials, to prevent hazards related to biocompatibility.

eliminate
hazard



2

Protective Measures

Add safeguards in the medical device itself or in the manufacturing process.

Example: Tamper-evident packaging and sterile barrier system to prevent contamination.

prevent
hazard



3

Information for Safety

Warnings, instructions, contraindications in the IFU, trainings.

Example: Clear reconstitution instructions specifying water volume, mixing technique, and 72-hour use-by window.

inform about
hazard

ISO/TR 24971, Risk Control examples

Table 6 — Examples of *risk control* measures

<i>Medical device</i>	<i>Hazard</i>	<i>Hazardous situation</i>	<i>Inherently safe design</i>	<i>Protective measure</i>	<i>Information for safety</i>
Syringe (for single use)	Biological contamination	Reuse after previous use on another patient	Self-destruction after use	Clear indication of first use	Warning against reuse
Implantable pacemaker	Loss of functionality	Pacemaker stops functioning due to early battery depletion	Reliable long-life batteries	Alarm before battery depletion	Information on typical battery lifetime
Mechanical patient ventilator	Air pressure	Software failure causes excessive pressure in patient airway	Blower incapable of delivering high pressure	Over-pressure valve in ventilator or in breathing hose	Instruction to use only breathing hose delivered by <i>manufacturer</i>
IVD blood analyser	Systematic error or bias	Incorrect result reported to clinician	Self-calibration	Metrologically traceable calibrators provided	Instruction to verify calibration with trueness controls
X-ray equipment	Ionising radiation	Staff exposed to stray radiation	Not feasible (stray radiation always occurs)	Lead shields and lead aprons	Information on radiation level in occupancy zones

Risk Control Measures, ideally defined as specific measurable requirements (with Req ID)

Risk Control Verification: VOI & VOE

Two distinct verification requirements per ISO 14971:2019 §7.2



Verification of Implementation (VOI)

"Has the risk control been implemented in the design?"

ISO 14971 §7.2: The manufacturer shall verify that the risk control measures have been implemented in the design.

What VOI confirms:

- The control is physically present in the design
- It was implemented as specified
- It is traceable to design outputs
- It exists in production units

Typical methods:

- Design specifications / review / inspection
- BOM / drawing verification
- Code review / static analysis



Verification of Effectiveness (VOE)

"Does the risk control actually reduce the risk as intended?"

ISO 14971 §7.2: The manufacturer shall verify the effectiveness, confirming that the risk is actually reduced to the intended level.

What VOE confirms:

- The control actually reduces the risk
- Risk is reduced to the intended level
- No new hazards are introduced (§7.3)
- No adverse effect on other controls

Typical methods:

- Functional / performance testing
- Fault injection / worst-case testing
- Simulated use / usability testing
- Stress testing
- Manufacturing process validation

Risk Control Verification: VOI & VOE

Two distinct verification requirements per ISO 14971:2019 §7.2



Verification of Implementation (VOI)

"Has the risk control been implemented in the design?"

Example questions:

- Is the tamper-evident seal on the vial packaging per specification?
- Does the IFU include the required reconstitution warnings?
- Is the needle gauge specified in the IFU correctly printed?



Verification of Effectiveness (VOE)

"Does the risk control actually reduce the risk as intended?"

Example questions:

- Does the tamper-evident seal reliably indicate if the vial has been opened?
- Do practitioners actually follow the reconstitution instructions correctly?
- Does the specified needle gauge achieve the intended injection depth?

→ Did you DO it?

→ Does it WORK?

Residual Risk & Benefit-Risk Analysis (§7.3-7.4)

Residual Risk Evaluation (7.3)

After each risk control is implemented, re-evaluate:

- Is the residual risk now acceptable?
- Has the control introduced any risks?
- If new risks are introduced, they must go through the full risk management process.
- If the residual risk remains **unacceptable**, find additional risk control measures or perform a Benefit-Risk Analysis



Critical: Risk Controls Can Introduce New Risks

Every risk control measure must be assessed for newly introduced hazards.

For example, specifying a smaller needle gauge (26G) to reduce tissue trauma may increase the risk of clogging during injection or inconsistent delivery of the PLLA suspension.

New risks must go through the complete risk management process from §5 onwards.



Benefit-Risk Analysis (7.4)

All practicable risk control measures have been applied - and yet - the risk remains **unacceptable ?**

‘benefit’

ISO14971 §3.2 defines

benefit

“positive impact or desirable outcome of the use of a medical device on the health of an individual, or a positive impact on patient management or public health

*Note 1 to entry: Benefits can include **positive impact on clinical outcome, the patient’s quality of life, outcomes related to diagnosis, positive impact from diagnostic devices on clinical outcomes, or positive impact on public health.**”*

*) EU MDR Art 2 (53) defines ‘**clinical benefit**’ similarly: “the positive impact of a device on the health of an individual, expressed in terms of a meaningful, measurable, patient-relevant clinical outcome(s), including outcome(s) related to diagnosis, or a positive impact on patient management or public health”

Benefit-Risk Analysis (§7.4)



When **individual** residual risk exceeds acceptability criteria

When Is It Required?

After all practicable risk control measures have been applied, if a **residual risk still exceeds the manufacturer's established acceptability criteria**, the manufacturer shall gather and review data/literature to determine whether the **benefits outweigh the residual risk**.

Key distinction:

This is NOT the same as the overall residual risk evaluation in §8. Benefit-risk under §7.4 is performed on **each individual residual risk** that exceeds acceptability.

If benefits do NOT outweigh:

Risk remains unacceptable. Redesign or restrict intended use.

Decision Flow

- 1 Apply all practicable risk controls to a given risk
- 2 Evaluate the residual risk against the established acceptability criteria
- 3 If residual risk NOT ACC → Perform benefit-risk analysis
- 4 If benefits outweigh residual risk → Acceptable → Document rationale & clinical evidence
- 5 If benefits do NOT outweigh risk → Not acceptable → Redesign device or restrict intended use

Performing Benefit-Risk Analysis Effectively

Structured approach per ISO 14971 §7.4



Define the Benefit

Identify the specific benefit related to the intended use

Benefit must be clinically meaningful - not commercial or convenience

ISO/TR 24971: Positive impact on patient health (e.g., early detection, improved diagnosis, **quality of life**, etc.)



Gather Evidence

Collect clinical data & literature:

- Published clinical studies
- State-of-the-art literature review
- Clinical experience / registry data
- PMCF / PMS data (if available)
- Comparable (predicate) device data

ISO/TR 24971: Evidence quality must be proportionate to the severity of the residual risk being justified



Weigh & Document

Structured comparison:

- Clearly state the residual risk
- Clearly state the clinical benefit
- Present supporting evidence
- Rationale: why benefit outweighs risk

The results of the benefit-risk analysis shall be recorded in the Risk management file.

Important: Benefit-risk analysis is a justification of last resort — it does not replace the obligation to reduce the risk through risk controls. All practicable risk controls must be applied first (ISO 14971 §7.1).

EU MDR GSPR 8

Individually and cumulatively



“All known and foreseeable risks, and any undesirable side-effects, shall be minimised and be acceptable when weighed against the evaluated benefits to the patient and/or user arising from the achieved performance of the device during normal conditions of use.”

Remember the “impossible situation” ?

(S=5, Death by septic shock, **NOT-ACC**)

NOT-ACC

does not mean "you can't have this risk in your risk analysis",
it means "this risk requires *Benefit-risk analysis*"

Criteria for risk acceptability / "Risk acceptability matrix"							
			Severity				
			1	2	3	4	5
Probability	Improbable	1	ACC	ACC	ACC	ACC	NOT-ACC
	Remote	2	ACC	ACC	ACC	NOT-ACC	NOT-ACC
	Occasional	3	ACC	ACC	ACC	NOT-ACC	NOT-ACC
	Probable	4	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC
	Frequent	5	ACC	ACC	NOT-ACC	NOT-ACC	NOT-ACC

An impossible situation? No.

The ISO14971 workflow offers the solution:

1. **Identify the risk** - death from septic shock. You can't omit a foreseeable harm.
2. **Reduce the risk AFAP*** - apply every technically feasible risk control measure (mandatory under EU MDR).
3. **Assess residual risk** against the matrix - after AFAP reduction, still P1/S5, your acceptability matrix says **NOT-ACC**
4. **Perform benefit-risk analysis** (ISO 14971 §7.4) - this mechanism exists precisely for this situation.
5. **Conclude** - Residual risk accepted on the basis of benefit-risk analysis (backed by justification and evidence).

→ The risk acceptability matrix is not the final word.

§7.4 Benefit-risk analysis gives you a legitimate way to accept a risk that your matrix flags as **NOT-ACC**, provided you can make the benefit-risk case. For a generic risk inherent to any percutaneous procedure (all aesthetic dermal fillers), the case is supported by **similar devices already being CE-marked**.

*) Without adversely affecting the benefit-risk ratio (EU MDR GSPR 2)

Step 1 - Reduce the risk as far as possible (AFAP)

Harm: Death from septic shock

Severity: S5 (Catastrophic)

Residual Probability: P1 (Improbable) <1 in 1,000,000 device uses

Acceptability: **NOT-ACC**

Risk control measures applied (AFAP reduction):

1. Product manufactured under validated aseptic processing and terminal sterilization
2. Bioburden limits specified and verified per release testing
3. Container closure integrity validated to maintain sterility through shelf-life
4. Instructions for Use specify aseptic injection technique, including skin disinfection protocol
5. IFU includes contraindication for use in patients with active skin infections
6. IFU includes post-injection care instructions and guidance to seek immediate medical attention at signs of infection
7. Practitioner training requirements specified in IFU

No further risk reduction measures have been identified that are technically feasible without fundamentally compromising the device's intended purpose as an injectable dermal filler.

Risk reduced AFAP has been demonstrated.

Step 2 - Document your Benefit-Risk Analysis (justification example below)

The residual risk of death from septic shock remains NOT-ACC per the risk acceptability criteria (Ref 1). A benefit-risk analysis is therefore performed in accordance with ISO14971 §7.4 to determine whether the benefits outweigh this residual risk.

*The residual probability of this harm occurring is “Improbable” (<1 in 1,000,000 device uses), reflecting the cumulative effect of all implemented risk control measures. The sequence of events leading to this harm **requires multiple sequential failures**:*

- a) breach of product sterility or aseptic technique during injection,*
- b) establishment of a clinically significant local infection,*
- c) failure of the patient to seek timely medical attention, and*
- d) failure of standard antibiotic therapy to resolve the infection before systemic progression.*

*Each step in this chain is independently mitigated by the risk controls provided (Ref 2). **The risk have been reduced as far as possible.***

*The risk of infection progressing to sepsis and death is not specific to this device. It is a well-recognized, inherent residual risk associated with any percutaneous procedure, including injection of dermal fillers, and is acknowledged in clinical literature and in the generally acknowledged **state of the art** for injectable products (Ref 3). The incidence of fatal sepsis from dermal filler injection is extremely rare and is not disproportionate to the risk associated with **similar medical devices already on the market** (Ref 4).*

The intended purpose of the device is to provide long-lasting dermal volume restoration for aesthetic improvement. The benefits to the user include improved appearance and associated psychological well-being, with documented patient satisfaction rates in clinical literature for dermal fillers (Ref 3). These benefits are achievable only through an injectable route of administration; no alternative delivery mechanism can achieve the intended purpose.

Considering the extremely low residual probability, the comprehensive risk control measures applied, the alignment with the state of the art for injectable procedures, and the fact that the benefit of the device can only be realized through injection, the benefit of the device is judged to outweigh this specific residual risk.

Conclusion: *The residual risk is accepted based on the benefit-risk analysis provided.*

Step 2 - Document your Benefit-Risk Analysis (justification example below)

The residual risk of death from septic shock remains NOT-ACC per the risk acceptability criteria (Ref 1). A benefit-risk analysis is therefore performed in accordance with ISO14971 §7.4 to determine whether the benefits outweigh this residual risk.

The residual probability of this harm occurring is “Improbable” (<1 in 1,000,000 device uses), reflecting the cumulative effect of all implemented risk control measures. The sequence of events leading to this harm requires multiple sequential failures:

- a) breach of product sterility or aseptic technique during injection,*
- b) establishment of a clinically significant local infection,*
- c) failure of the patient to seek timely medical attention, and*
- d) failure of standard antibiotic therapy to resolve the infection before systemic progression.*

Each step in this chain is independently mitigated by the risk controls provided (Ref 2). The risk have been reduced as far as possible.

*The risk of infection progressing to sepsis and death is not specific to this device. It is a well-recognized, inherent residual risk associated with any percutaneous procedure, including injection of dermal fillers, and is acknowledged in clinical literature and in the generally acknowledged **state of the art** for injectable products (Ref 3). The incidence of fatal sepsis from dermal filler injection is extremely rare and is not disproportionate to the risk associated with **similar medical devices already on the market** (Ref 4).*

The intended purpose of the device is to provide long-lasting dermal volume restoration for aesthetic improvement. The benefits to the user include improved appearance and associated psychological well-being, with documented patient satisfaction rates in clinical literature for dermal fillers (Ref 3). These benefits are achievable only through an injectable route of administration; no alternative delivery mechanism can achieve the intended purpose.

Considering the extremely low residual probability, the comprehensive risk control measures applied, the alignment with the state of the art for injectable procedures, and the fact that the benefit of the device can only be realized through injection, the benefit of the device is judged to outweigh this specific residual risk.

Conclusion: The residual risk is accepted based on the benefit-risk analysis provided.

“State of the art” ?

ISO14971 §3.28 defines

state of the art

“developed stage of technical capability at a given time as regards products, processes and services, based on the relevant consolidated findings of science, technology and experience”

NOTE The state of the art embodies what is currently and generally accepted as good practice in technology and medicine. The state of the art does not necessarily imply the most technologically advanced solution. The state of the art described here is sometimes referred to as the “generally acknowledged state of the art”.

*) “State of the art” must be considered per EU MDR GSPR 1

Reflection on our Benefit-Risk Analysis

Key elements that make our Benefit-Risk Analysis defensible:

- The "state of the art" and similar device argument is critical:
 - ✓ Every dermal filler, every injectable, every surgical procedure carries this same residual risk.
 - ✓ If a notified body rejected this rationale, *they'd logically have to reject every non-medical purpose dermal filler already on the market*
- The "no alternative delivery mechanism" point closes the door on the obvious challenge: "why not make it non-injectable?", the answer is that the intended purpose is impossible without injection, so removing the injection route eliminates the device entirely rather than reducing risk.
- The causal chain argument shows that death isn't a single-point failure, but requires *multiple independent failures*, which supports the "Improbable" P-estimate (ideally supported by CER and PMS data).

Flashback to the EU Common Specification

For non-medical purposes devices, the EU Common Specifications (Regulation 2022/2346), raises the bar on risk management, as the benefit-side of the equation is weaker (no life-saving, or therapeutic benefit).

Regulation 2022/2346, Annex I §3.3:

- 
- 3.3. In defining the criteria for risk acceptability in accordance with the principles established by the policy referred to in Section 2.2, manufacturers shall consider that all risks, including those related to surgical intervention, are to be eliminated or reduced as far as possible. If the undesirable side-effects are of transient nature and do not require medical or surgical intervention to prevent life-threatening illness or permanent impairment of a body function or permanent damage to a body structure, residual risks may be considered as being acceptable. If one or more of the conditions laid down in this Section is not met, the manufacturer shall provide a justification explaining the reasons for the acceptability of the risks.



“... the manufacturer shall provide a justification ...”



CLAUSES 8 & 9

Evaluation of Overall Residual Risk & Risk Management Review

The big-picture assessment and completion check

Evaluation of Overall Residual Risk (§8)

After all individual risk controls are implemented and verified, the manufacturer shall evaluate the overall residual risk posed by the device.

What does this mean in practice?

- Consider cumulative effects → Multiple individually acceptable risks may combine into an unacceptable overall risk profile.
- Use the method defined in the Risk Management Plan (this must be pre-defined, not ad hoc), e.g., a combination of
 - a) residual risk plotting (quantitative),
 - b) medical expert judgement (qualitative), and
 - c) comparison to similar medical devices (qualitative).

Information for Safety Disclosure

If overall residual risk is deemed acceptable, the manufacturer must disclose any remaining residual risks in the accompanying information (IFU).

This ensures that users and patients are informed about the limits of risk reduction achieved by the device.

Evaluation of Overall Residual Risk (\$8)

Residual risk plotting – an effective way to visualize the device’s overall risk profile.

Residual risk plot - **Device A**

P \ S	1: Negligible	2: Minor	3: Serious	4: Critical	5: Catastrophic
5: Frequent	★				
4: Probable		★			
3: Occasional	★				
2: Remote	★ ★	★			
1: Improbable	★	★ ★	★		

Acceptable
 "Tolerable"
 Unacceptable

Residual risk plot - **Device B**

P \ S	1: Negligible	2: Minor	3: Serious	4: Critical	5: Catastrophic
5: Frequent	★				
4: Probable		★ ★			
3: Occasional		★	★ ★		
2: Remote			★	★ ★	
1: Improbable					★

Acceptable
 "Tolerable"
 Unacceptable

Risk Management Review (\$9)

Prior to release for commercial distribution of the medical device, the manufacturer shall review the execution of the risk management plan.

This review shall at least ensure that:

- ✓ The **risk management plan** has been appropriately implemented
- ✓ The **overall residual risk** is acceptable
- ✓ Appropriate methods are in place to collect and review **production and post-production information**

Updating the RMR

There can be a need to update the Risk Management Report

- if new information becomes available (e.g., in PMS), or
- with major design changes.

The manufacturer decides.

The responsibility for review shall be assigned in the Risk Management plan to persons having the appropriate authority

The results of the **Risk Management Review** shall be recorded and maintained as the **Risk Management Report**

Activity

Deliverable

CLAUSE 10

Production & Post-production

The feedback loop that keeps risk management alive

Production & Post-production activities (\$10)

The manufacturer shall establish, document, implement, and maintain a **system** to actively collect and review information about the medical device in production and post-production phases.

Information collection (10.2)

Information generated:

- During production and monitoring (e.g., deviations)
- From complaints and customer feedback
 - Reason for complaint, date, hazard, P/S of any harm, place of use, component involved, UDI, person identifying the problem, etc.
- By those accountable the installation and maintenance
- By the supply chain
- Publicly available information about similar devices
- Information related to state-of-the-art
- Post-market surveillance reports (PMSR/PSUR)
- Clinical follow-up data (PMCF)
- Trend analysis results

Information review & Actions (10.3-10.4)

1. Review collected information for relevance to safety
2. Determine if previously unrecognized hazards or hazardous situations exist
3. Determine if estimated risks are no longer acceptable
4. Feed the information back into the RMF and take appropriate action
5. Evaluate impact on previously implemented risk control measures

→ **ISO/TR 24971** provides a helpful list of questions to ask

When the Feedback Loop Breaks

BSI Audit Finding: NC outcomes not integrated into risk management files → CAPA 008-25

What Happened

- Internal nonconformities identified real-world risks (e.g., process deviations during manufacturing/testing, etc).
- Corrective actions for the NCs were properly implemented.
- **However, the risks identified were NOT reflected in the product risk analysis or QMS risk analysis.**
- The NC form marked risk review as "completed" - but the risk files were never actually updated.

Root Cause & Lesson Learned

Root cause: The NC procedure lacked a "hard stop" - a mandatory, verifiable checkpoint requiring documented evidence that risk files were updated before NC closure.

Lesson learned: Risk management integration requires traceable, verifiable records - document ID, version, and specific risk ID(s).



Takeaway

Your NC/CAPA process must have a closed-loop connection to your risk management files. Every nonconformity with potential risk implications must be traceable to a documented risk assessment update - or a documented rationale for why no update was needed.

Trend Analysis & EU/UK MDR



Trend Analysis in Risk Management

Based on information collected from production and PMS.

Purpose in risk management context:

- Detect early risk signals to support the implementation of *preventive* actions (CAPA), eliminating the causes of **potential** NCs (e.g., in production)
- Identify emerging hazards not captured in the original risk analysis
- Provide objective evidence that risk controls remain effective over time
- Challenge your risk estimations: are the probabilities you assumed still valid? (PMS data may indicate otherwise)
- Trigger risk management file updates when trends indicate a change



EU & UK MDR - Trend Reporting

EU MDR Article 88 / UK MDR 44ZN requires manufacturers to report to competent authorities any statistically significant increase in the frequency or severity of incidents* or expected undesirable side-effects.

This directly links to risk management:

- A detected trend may challenge the validity of your probability estimates in the risk analysis
- Trend reporting puts regulatory pressure on maintaining accurate, up-to-date risk estimations
- Your trend analysis method must be robust enough to detect real signals, not just noise (utilize moving average, plotting, etc.)

*) Per UK MDR, all incidents. Per EU MDR, non-serious incidents only.

Key Takeaways



Risk management is a lifecycle activity - it starts **before** design and continues **forever** (PMS/NC/CAPAs feed back into the RMF)



The Risk Management Plan defines your approach **before** you begin – criteria for risk acceptability, methods, responsibilities



Reasonably foreseeable misuse is in scope of ISO14971 - do not limit your analysis to the IFU alone



Verify both **implementation** AND **effectiveness** of every risk control measure (RCM). Define RCMs as **requirements**.



“NOT ACC” per your risk acceptability criteria is not the end of the story. Benefit-Risk Analysis is your secret weapon.



Trend analysis under EU/UK MDR puts pressure on maintaining accurate risk estimations

What's Next?

Part B: Risk Analysis Workshop

Techniques to support risk analysis + Hands-on exercise

Thank you - Questions & Discussion